

2026.09.12 · 배포 전 검증본

MYSBIZON

오늘 작업 및 보안 검증 보고서

서버가 어떻게 연결되는지, 무엇을 고쳤는지, 운영 전에 무엇을 확인해야 하는지 초보자도 따라갈 수 있게 정리했어요.

현재 결론

디자인 시스템, 지도·비교·손익·창업 준비 흐름과 관리자 2차 인증을 고쳤고 자동 검사를 통과했어요. 운영 사이트에는 아직 새 수정본을 배포하지 않았어요.

브랜치 `codex/refactor-responsive-ux-20260911` · 이 보고서와 코드를 함께 커밋

한눈에 보는 오늘의 결과

항목	완료한 내용	현재 상태
디자인	Warm · Clear · Assured 문법으로 색·글자·간격·카드·버튼을 통일	PC·태블릿·모바일 확인
의사결정	지도 한 지점, 500m 경쟁, 후보 2~5곳, 손익, 창업 준비를 한 흐름으로 연결	코드·테스트 완료
관리자	2차 키를 별도 헤더로 보내고 15분 HttpOnly 세션으로 새로고침 유지	운영 배포 후 적용
문의 영역	하단에 문의 카드와 이메일 자리를 생성	주소 미설정 시 '준비 중'
개인정보	실제 기능 상태를 공개 설정 API에서 읽어 표시	고객 수집은 계속 꺼짐
검증	HTML, 데이터, 76개 자동 검사, 배포 묶음, 모바일·태블릿 화면 확인	통과

사용자가 체감하는 변화

- 처음 들어오자마자 큰 소개창에 막히지 않고 업종과 지역을 고를 수 있어요.
- 서울 전체를 보는지, 특정 구 안에서 비교하는지와 실제 표본 수가 화면에 보여요.
- '예상 매출'처럼 오해할 표현을 '상권 참고 매출 (추정)'으로 통일했어요.
- 원가율이 100% 이상이면 억지 계산 대신 잘못된 값을 바로 알려줘요.
- 지도 API가 실패해도 번호가 붙은 상권 목록으로 계속 탐색할 수 있어요.
- 선택 위치의 매출·수요·경쟁을 먼저 보고 한 줄 판단과 상세 자료를 이어서 볼 수 있어요.

기억할 점

GitHub에 올라간 새 코드는 검증됐지만, 공개 사이트는 아직 이전 릴리스예요.
관리자 2차 키 수정과 새 문의 영역은 운영 배포 뒤부터 보여요.

서버는 이렇게 연결돼요

들어오는 곳	중간 문	실제 프로그램
고객 브라우저 HTTPS 443	Nginx 도메인-SSL-요청 전달	Node 웹앱 127.0.0.1:3000
관리자 브라우저 /admin/	Nginx 1차 비밀번호	관리자 Node 127.0.0.1:3102
서버 내부	외부 공개 없음	FastAPI 8000 · PostgreSQL 5432

포트는 방 번호와 비슷해요

외부에서는 443번 문만 열고 들어와요. Nginx가 요청을 받아 화면 앱은 3000번, 기존 Python 기능은 8000번으로 전달해요. 3000-8000-5432는 127.0.0.1 또는 localhost에만 묶여 있어 인터넷에서 직접 접속할 수 없어요.

포트	용도	인터넷 공개
22	SSH 서버 관리	열림 · 키 인증 필요
443	HTTPS 공개 웹사이트	열림
3000	Node 고객 화면	서버 내부만
3102	Node 관리자 API	Nginx를 통해서만
8000	기존 FastAPI	서버 내부만
5432	PostgreSQL DB	서버 내부만

왜 Node와 Python 이 둘 다 있나요?

Python VPS를 잘못 산 것이 아니에요. VPS에는 필요한 프로그램을 함께 설치할 수 있어요. 현재 화면-관리자 기능은 Node가 맡고, 기존 FastAPI는 별도 내부 포트에서 유지돼요.

관리자 2차 키가 틀렸다고 나온 이유

관리자 주소에는 인증이 두 겹 있어요. 첫 번째는 브라우저가 띄우는 사용자명·비밀번호 창이고, 두 번째는 관리자 화면 안에 붙여 넣는 긴 키예요.

단계	어디에 입력하나요?	역할
1차	브라우저 팝업 · 사용자명 mysbizon-admin	관리자 URL 자체를 보호
2차	관리자 페이지 안 '2차 관리자 키' 입력칸	고객 데이터 API 권한 확인

문제

두 단계가 모두 HTTP의 Authorization 헤더를 사용했어요. 관리자 화면이 2차 키를 보내는 순간 브라우저가 기억한 1차 Basic 인증값을 덮을 수 있었어요. 그래서 키가 맞아도 실패하거나 1차 로그인창이 다시 나타났어요.

해결

```
1차: Authorization: Basic ... (Nginx가 확인)
2차: X-Mysbizon-Admin-Key: ... (관리자 앱이 확인)
```

서로 다른 봉투에 넣어 보내도록 바꿨어요. 올바른 2차 키를 한 번 확인하면 서버가 15분짜리 HttpOnly 세션을 발급해 새로고침 뒤에도 이어집니다. 키는 브라우저 저장소에 남지 않고, 로그아웃하면 세션이 바로 폐기돼요. 2차 실패는 403으로 구분해 1차 로그인창을 다시 띄우지 않아요.

비밀키 취급

2차 관리자 키는 채팅·문서·GitHub에 적지 말고 비밀번호 관리자에 보관하세요. 이번 코드와 PDF에는 실제 키가 들어 있지 않아요.

MYSBIZON DESIGN GRAMMAR v1.0

영역	적용 기준
인상	Warm · Clear · Assured · 친근하지만 가볍지 않은 데이터 서비스
색	중립색 중심 · Bizon Mint #32B99A는 CTA·선택·현재 상태에만 사용
글자	Wanted Sans Variable · Hero 42/54 · Page 32/44 · 주요 숫자 40/44
면	일반 카드는 흰 배경·1px 테두리·16px radius·그림자 없음
간격	4·8·12·16·24·32·48·72px 체계 · PC 최대 1280px
움직임	일반 160~220ms · 패널 220~280ms · 반복 애니메이션 최소화

정보 순서

지도 결과는 상권 참고 월매출 → 유동인구 → 500m 경쟁점 세 가지를 먼저 보여 줍니다. 바로 아래 한 줄 판단을 놓고, 프랜차이즈·개인점포와 업종 1~3순위는 상세 정보로 이어집니다. 민트색은 선택과 행동에만 사용하고 일반 정보는 글자·선·여백으로 구분했어요.

화면별 정리

- 홈은 업종과 위치 입력, 한 개의 주요 버튼을 먼저 보여 줘요.
- 지도는 사용자가 고른 핀 한 개를 중심으로 하고 주변 업체는 버튼을 누른 뒤에만 표시해요.
- 후보 비교는 상권 이름을 몰라도 구 목록에서 찾고 최대 다섯 곳까지 저장해요.
- 일반 카드와 CTA의 장식 그림자를 없애 숫자와 판단 문장이 먼저 읽히게 했어요.

데이터와 숫자를 어떻게 바로잡았나요?

사례	계산	화면 결과
기본 가정	고정비 990만원 ÷ (1 - 원가율 35%)	본전 1,523만원
참고 매출	3,720만원 × 65% - 990만원	월 1,428만원 남음
원가율 100%	나눠셈 분모가 0	계산 중단 · 수정 안내
시나리오	참고 매출의 70% · 100% · 130%	같은 고정비로 비교

순위와 비교 범위

- 지역을 고르지 않으면 서울 전체 1,405곳, 강남구를 고르면 해당 구 81곳처럼 범위를 다시 계산해요.
- 직접 고른 상권이 전체 216위여도 후보 목록 첫 줄에는 실제 1위가 표시돼요.
- 저장한 후보 2~5곳 비교에서는 기간, 지표, 표본 범위를 함께 보여줘요.
- 상권 소비 규모와 손님 수를 같은 뜻으로 부르던 문구를 바로잡았어요.

숫자의 한계

표시되는 매출은 새 점포가 앞으로 벌 금액이 아니에요. 공개된 상권 소비액과 점포 수를 가공한 참고 통계예요. 세금, 대출이자, 개별 점포 임대료는 사용자가 별도로 확인해야 해요.

보안과 개인정보 상태

보호 장치	확인한 상태	뜻
SSH	공개키만 허용 · root 로그인 차단	비밀번호 대입 공격으로 바로 로그인할 수 없음
방화벽	22·443만 허용	불필요한 외부 진입로 차단
Fail2ban	sshd jail 동작	반복 공격 IP를 자동 차단
DB	localhost만 수신	인터넷에서 DB 포트 직접 접근 불가
앱	Node 3000 · Python 8000 내부 수신	Nginx 보안 규칙을 거쳐야 접근
고객 수집	비활성	법적 문구·운영 주체 확정 전 저장 안 함

공개 서버의 공격 로그는 이상한 일이 아니에요

인터넷에 공개된 IP는 자동 스캐너가 root, ubuntu, admin 같은 계정과 phpinfo.php, graphql 같은 주소를 계속 시험해요. 당시 로그의 Invalid user와 404는 시도가 거절됐다는 뜻이에요. 성공 로그인 기록은 본인 IP와 대조해야 해요.

보안의 현실

현재 설정은 기본 방어가 잘 잡힌 상태예요. 그래도 '절대 안 털린다'는 보증을 할 수 없어요. 운영체제·Nginx·Node·Python 패키지 업데이트, 백업 복구 시험, 로그인·오류 로그 감시는 계속해야 해요.

개인정보 안내

화면은 브라우저 저장, 서버 접속 로그, 이메일, 고객 DB, 익명 클릭 통계를 나눠 설명하고 실제 켜짐·꺼짐 상태를 서버에서 읽어요. 운영 주체, 문의처, 보유기간, 외부 처리업체가 확정되기 전에는 고객정보 수집을 켜지 않도록 유지했어요.

하단 문의 영역과 디자인 치수

디자인 대상	측정값	디자인팀 전달값
검정 배경	원본 1,918×738px · 상단 헤더 10px	헤더 제외 1,918×728px
민트 카드 원본	캔버스 1,144×475px	아트보드 1,144×475px
민트 카드 실영역	약 1,139×474px	약 1,140×474px
2배 납품	배경 3,836×1,456px · 카드 2,288×950px	선명한 고해상도 시안

새 문의 이메일 영역

본문 아래에 별도 카드로 만들었어요. 왼쪽에는 '서비스 이용 문의' 설명, 오른쪽에는 이메일 주소가 들어갈 64px 높이 슬롯이 있어요. 주소를 아직 정하지 않았기 때문에 가짜 이메일을 쓰지 않고 '준비 중'으로 표시해요.

화면	확인한 카드 크기	동작
데스크톱	약 1,206×120px (확인한 화면)	좌우 2단
모바일 390px	약 348×194px	설명과 이메일 칸이 세로로 쌓임

```
PUBLIC_CONTACT_EMAIL=company@example.com
```

운영 서버 환경 파일에 실제 회사 주소를 위와 같이 넣고 서비스를 재시작하면 공개 설정 API를 통해 하단에 표시돼요. 형식이 잘못된 주소와 줄바꿈이 섞인 값은 공개하지 않아요.

초보자용 서버 명령 해설

서버 접속

```
ssh -i "C:\SSH KEY\id_ed25519.txt" deploy@172.238.24.43
```

내 컴퓨터의 개인키로 deploy 계정에 로그인해요. 개인키 파일을 가진 것으로 끝나지 않고 서버에 짝이 맞는 공개키가 등록돼 있어야 해요.

서비스 상태

```
sudo systemctl status mysbizon-node --no-pager
```

Node 프로그램이 실행 중인지, 최근 오류가 있는지 봐요.

내부 건강 확인

```
curl --fail http://127.0.0.1:3000/healthz
```

서버 안에서 Node가 응답하는지 확인해요. {"ok":true}면 기본 응답이 정상이에요.

열린 포트

```
sudo ss -ltnp
```

어떤 프로그램이 어떤 포트에서 기다리는지 봐요. 3000-8000-5432가 127.0.0.1이면 외부에 직접 공개되지 않은 상태예요.

방화벽

```
sudo ufw status verbose
```

인터넷에서 들어올 수 있는 포트를 확인해요. 현재 기준은 22와 443이에요.

검증 결과와 다음 단계

검사	결과
자동 검사	76개 시나리오 모두 통과
HTML	화면 조각과 생성된 index.html 일치
배포 번들	원본 로직과 app.bundle.js-data.bundle.js 일치
데이터	10개 파일 · 상권 1,564곳 · 업종 62개 · 2026년 1분기
배포 묶음	71개 파일 · 자체 호스팅 글꼴 포함
반응형	390px-834px-1280px에서 가로 넘침 없음

GitHub

코드·문서·검증 보고서를 브랜치 codex/refactor-responsive-ux-20260911에 함께 커밋해요.

운영 전에 필요한 승인

관리자 2차 키 수정, 문의 영역, P0 화면 변경을 공개 사이트에 적용하려면 이 커밋을 서버에 한 번 더 배포해야 해요. 배포 전에는 현재 릴리스 백업과 자동 복구 절차를 유지하고, 배포 직후 공개 홈·관리자 1차·2차·healthz를 확인해야 해요.

남은 제한

- 로컬 환경에는 카카오 키를 넣지 않아 실제 지도 타일 대신 실패 대체 흐름을 확인했어요.
- 이메일 발송과 고객 DB 저장은 꺼져 있어 실제 외부 발송·운영 DB 입력은 실행하지 않았어요.
- 실제 기기의 키보드·브라우저 조합과 예비 창업자 대상 사용성 조사는 별도예요.
- 임대료·공실은 모든 상권의 개별 점포 자료가 아니며 현재 분석 범위는 서울·2026년 1분기예요.

참고: 개인정보보호위원회 '2026 개인정보 처리방침 작성지침' · https://www.privacy.go.kr/front/bbs/bbsView.do?bbsNo=BBSMSTR_00000000049&bbscttNo=20885